Monthly Intelligence Dispatch

April 2020

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB: Spyware is in the lead in mailings that feed off the coronavirus crisis.
- South Korean and US bank card data worth nearly **$2 million** has been put up for sale on the darknet.
- Group-IB detected a sharp increase in the sales of phishing kits, which are tools for large-scale development of phishing websites. Last year, Group-IB's Threat Intelligence system detected over 16,200 unique phishing kits.
- The North Korean threat group Lazarus carried out a phishing campaign against South Korean users.
- Group-IB's Threat Intelligence specialists discovered posts that advertised the sale of over 4,000 Zoom user accounts on three underground platforms.
- The Moscow police, with the assistance of Group-IB, arrested the operators of a fraudulent resource that sold fake digital passes for people to move around their cities during the lockdown.

COVID-19

Between February 13, 2020 and April 1, 2020, Group-IB's Computer Emergency Response Team (CERT-GIB) analyzed hundreds of phishing emails disguised as COVID-19-related newsletters and commercial mailings. Nearly **65%** of malicious emails intercepted by Group-IB's Threat Detection System (TDS) carried spyware; backdoors came second at **31%**, with ransomware accounting for **4%**. The Trojan **AgentTesla** topped the list of the most active spyware. The fake emails were written in Russian and English and purported to be from reputable international organizations (**WHO**, **UNICEF**) as well as major Russian and International companies. The emails targeted both the commercial and government sectors in Russia and other post-Soviet countries. While the percentage of COVID-19-related phishing emails is small and amounts to about 5% of all malicious traffic analyzed over the review period, threat actors seek to take advantage of the global panic to increase their malware sales on hacker forums. In addition, Group-IB's Threat Intelligence team tracked down over **500** posts on underground platforms in which users offered discounts and promotional codes for DDoS, spamming, and other services to stimulate demand, affected by the pandemic. For example, a Java loader disguised as an interactive COVID-19 distribution map was put up for sale in February. The main infection vector is an ordinary phishing email, which — the seller claims — bypasses Gmail protection by using legitimate file extensions. Once infected, the user is shown a map with up-to-date WHO and Johns Hopkins University data while a malicious payload is downloaded. The payload could be anything, for example data stealing malware. Later, in March, researchers detected similar emails that involved the **AZORult** stealer.

Lazarus	The North Korean threat group Lazarus carried out a phishing campaign against South Korean users, researchers at Chinese company Qianxin reported. The emails, which purported to be from the Incheon Communicable Diseases Center, involved malware and contained a fake coronavirus distribution report. The steps that followed were typical: script, malware download, etc. Lazarus APT is a state-sponsored North Korean hacking group controlled by Bureau 121, a cyberoperations agency that is part of the North Korean Reconnaissance General Bureau.
HawkEye	On April 3, **CERT-GIB** detected another wave of **HawkEye** spyware mailings, this time even Group-IB's PR department was among the recipients. The dangerous email was detected and neutralized by our Threat Detection System (TDS). The message purported to be from a representative of a trading partner in Japan, who expressed concerns about Italy suspending the production of a product they needed because of the coronavirus crisis and inquired about the possibility of making an order and what the delivery timescales would be. The email contained an MS Word file called "PO 2020 supply.doc," which acted as a loader of a HawkEye (aka HawkSpy) spyware program. In late March, this program was sent out disguised as a Chinese company's proposal to start a joint business to produce protective medical masks.

TinyPosh

On April 7, 2020, Group-IB detected an upload of malicious LNK files to VirusTotal. The attack allegedly happened between 31 March and 2 April. The mailout purported to be from the self-regulatory organization MIR. A second attack took place on April 24. Its scheme was the same, but involved a different decoy document and command and control (C&C) server for the Trojan. The mailing purported to be from a dental clinic called Novadent. Launching the shortcut file resulted in the decoy document being shown to the user and the **TinyPosh** backdoor being installed on the computer. The backdoor ensures persistence in the system and can download and launch other programs on command from the C&C server.

Ocean Lotus

Between January and April 2020, the Vietnamese threat group **APT32** (aka **Ocean Lotus** and **Cobalt Kitty**) carried out several phishing campaigns targeting Chinese government agencies, FireEye reported. There is a suggestion that the attack was carried out with the aim of collecting information about COVID-19. APT32 is a state-sponsored Vietnamese hacking group active since at least 2014; the group is known to have conducted multiple cyberoperations pursuing the interests of the Vietnamese government.

SHERIFF

Since early 2019, an Exploit.in (an underground forum) user with the nickname **SHERIFF** has been actively selling access to websites' admin panels and databases. SHERIFF noted that they used specialized penetration testing software such as SIB service, **X-MapAdmin, and OWASP ZAP** to search for vulnerabilities. In 2019–2020, they put up for sale over 100 instances of access to and databases of various organizations that included major international companies. Generally, Group-IB has been recording a rise in the sales of access to corporate networks on hacker forums since the second half of 2019. This is primarily due to the appearance of new players in the market: in the second half of 2019 the number of sellers was 58% higher than in the first half of that year and 92% higher than in the second half of 2017. Another factor for the increased demand for access — and consequently increased supply — is a big number of new cryptolocker partner programs. The active growth in the sales of access to corporate networks started in 2017 and peaked in 2018 after minor irregularities caused by some sellers' temporarily stopping their activities. In particular, between October 2017 and September 2019, one of the most notorious threat actors selling such services alone (!) put up for sale access to the networks of 135 companies from over 40 countries.

Zoom

Group-IB's Threat Intelligence specialists discovered posts that advertised the sale of **Zoom** user accounts on three underground platforms. The total number of unique user accounts published online is currently **4,153**, which includes 31 accounts of users whose email addresses are in the .ru domain. The danger lies in the fact that a large number of users use the same password for different services. By obtaining a user's login and password for one service, threat actors may try to use it to access accounts on other platforms. To avoid this, one should — at the very least — use strong and different passwords for different services and enable two-factor authentication where possible.

South Korea

Group-IB discovered a database with nearly **400,000** bank card dumps, uploaded to a popular darknet card shop on April 9. The database contains information on credit and debit cards issued by banks and financial organizations in **South Korea** and the **United States**. This is the largest sale of South Korean card dumps in 2020: over 49% of records in the database belong to banking customers from that country. A dump is bank card magnetic stripe data. The source of the compromise is yet unknown. Group-IB informed relevant bodies in South Korea and the US to help them take the necessary steps to protect customers.

Double strike

Group-IB has detected a new wave of fraudulent activity, in which users that have already fallen victim to malefactors online are offered VAT refunds or compensation to recover damages from participating in popular fake surveys and lottery scams; instead, they have their bank card data stolen and money withdrawn. Threat actors pose as non-existent organizations: One-stop Refund Center, National Lottery Association, Financial Protection Center, and others. CERT-GIB discovered an entire network of inter-related websites that included over 170 domain names registered to one entity. In March 2020, another three dozen new domains related to the VAT refund scheme appeared. Attacks usually start with messages distributed through messaging apps, email, or social media. Fraudsters both send cold messages and target victims of previous campaigns, since various schemes (e.g. Rabbit Hole) involve the collection of user data in order for threat actors to reuse them for spamming purposes or to distribute links to new fraudulent offers.

Since April 13, Group-IB's Brand Protection & Anti-piracy Department has been detecting a sharp increase in the number of new fraudulent resources that feed off the coronavirus lockdown–related pass system in Russia. At first, fraudsters offered their services exclusively on specially crafted landing webpages and Telegram channels, but on April 14 they started using Instagram accounts, offering "a quick solution to the problem" of obtaining an electronic pass. The price for a pass on the websites ranges between $40 and $61. The "passes" are promised to be delivered through a courier service. In Telegram channels, prices vary between $40 and $75 and the "passes" are delivered digitally. On Instagram, fraudsters offer issuing a pass for $40 and say that the "Q-Kod" (as it is described in the post) will be delivered within 40 minutes. As an additional option, they offer certificates stating that the person's workplace is a grocery store ($41) as well as pharmacist IDs ($68) and doctor IDs ($95), since there are no lockdown restrictions on these occupations. As at Sunday, April 26, the Information Technology Department of Moscow together with Group-IB's Brand Protection & Anti-piracy Department discovered 126 fraudulent resources that sold digital passes: 25 websites, 35 social media groups and accounts and 66 Telegram channels. Group-IB blocked 78 resources and the blocking of the rest is underway.

In April, CERT-GIB discovered a new fraud scheme that took advantage of the COVID-19 crisis. In the evening of April 10, targeted fake text or instant messages were distributed, claiming that based on their geolocation data the recipients breached lockdown rules. Fraudsters cited a non-existent Russian Federal Penitentiary Service decree and demanded that a fine of $55 be paid within 24 hours by transferring money to a Russian phone number. Failure to pay the fine within 24 hours would result in a criminal case under article 236 of the Russian Criminal Code (Violation of sanitary and epidemiological rules that by negligence has resulted in mass diseases or poisoning of people). Calling the specified number leads to an alleged "Russian Ministry of Internal Affairs helpline." Last year, Russian Federal Penitentiary Service "decree" No. 168-322 was cited to "fine" porn site visitors. This type of fraud is usually committed by prisoners.

Phishing kits

Group-IB detected a sharp increase in the sales of phishing kits, which are tools for large-scale development of phishing websites. Last year, Group-IB's Threat Intelligence system detected over 16,200 unique phishing kits. The number of offers and sellers on underground forums doubled. The average price grew by 149% jumping to $304 per kit. A phishing kit is an archive file containing scripts necessary for creating and operating a phishing website. This type of tool enables threat actors without considerable programming skills to quickly deploy hundreds of phishing pages, often using them as mirrors. When such a website is blocked, fraudsters activate another one; if it also gets blocked, yet another one is used and so on. In 2019, phishing kit creators' favourite brands, which were used to create fake pages, were Amazon, Google, and Office 365.

Cerberus

An updated version of the Android banking Trojan **Cerberus** was put up for rent on XSS.is, an underground forum. The seller is known under the nickname ANDROID. The updated **Cerberus** retained all the features of the previous version, including support for web fakes, a keylogger, form grabber, USSD requests, ability to send and intercept SMS messages, support for remote access, bypass of security restrictions and antivirus solutions, etc. On April 7, another XSS.is post by ANDROID was discovered, which advertised the sale of the source codes of an older Cerberus version.

mr.SNIFFA

In late 2019, an Exploit.in user with the nickname Billar made a post in which they put up for sale a new bank card sniffer (not fully developed). On March 25, they started selling the sniffer's release version called **mr.SNIFFA**. According to the post, this sniffer is a compilation of various code pieces (from different authors), which the seller put together into one program. The post offers something closer to an alpha version, rather than a release version of the sniffer. The seller offered it for $100 to first users and planned to sell the release version for $1,000.

Arrests and sentences

COVID-fake

The Moscow police, with the assistance of Group-IB, arrested the operators of a fraudulent resource that sold fake digital passes for people to move around their cities during the lockdown in Moscow, Saint Petersburg, and Krasnodar. A criminal case was opened under **article 159 of the Russian Criminal Code** (Fraud). The fraudsters used a popular messaging app and posed as law enforcement officers, promising to help people obtain passes "on the Gosuslugi.ru public services portal using a semi-legal scheme" as they said. The scammers asked their victims to send their passport information as well as license plate number if a pass for a vehicle was needed. Once the fraudsters received money via bank card transfers, they disappeared. In two weeks they managed to make several deals. The price for their services varied between **$38** and **$45**. The victims were usually those who were too worried about the movement restrictions and did not wait until the official passes started to be issued.

Europol arrested a fraudster in **Singapore** after a suspicious transaction that requested the transfer of stolen money was detected and blocked. The fraud resulted in a pharmaceutical company losing **€6.5 million**. The fraudster posed as a representative of a company that offered quick supply and delivery of surgical masks, hand sanitizer, and products for fighting **COVID-19**. After the pharmaceutical company transferred the funds, the products were never delivered and the supplier disappeared.

Forecasts and warnings

- Silence might stop attacking banks and start making money by encrypting data, a method other threat actors have been using lately.
- Shifting employees to remote work entails additional cybersecurity risks for companies. This is primarily due to the fact that not everyone can ensure proper protection for a wide-area infrastructure and implement the same organizational and technical security measures as in office spaces; not all businesses have that experience. There is an increased risk of attacks with the aim of espionage.
- Even though published information about South Korean banks' cards is not enough to make online purchases, fraudsters who buy this data can still monetize it. One way to do it is to clone a card (so-called *white plastic* cards) and use it to withdraw money from ATMs or buy goods in physical stores.
- FlexNet will attack users of Android mobile devices in Russia.
- The banking Trojan Ramnit will be a relevant threat for Japan. It might also attack some European banks and financial organizations. The geographical scope of Trickbot will be as large, but this Trojan will also be active in Japan.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com